NIST CSF 2.0 Gap Assessment — Small Business

Self-directed assessment | Aarohi Nanajkar | Date: 9 October 2026

1. SCOPE

I run Crumbline Cookies, a home bakery that sells cookies and other baked goods. Orders and customer conversations come in through social media (mainly Instagram) and my phone, payments are received through digital payment apps, and I keep customer contact details and an order register on my phone. The assets that would hurt most to lose are the business's social media account, the customer and order records, and my recipes. The main risks are account hacking, fake payment confirmations, loss of customer information and accidental deletion of records. This assessment compares my current practices against NIST CSF 2.0, identifies the gaps, and recommends practical actions for a business with limited time and money.

2. ASSESSMENT BY FUNCTION

Function	Current practice	Target practice	Gap	Action	Priority (H/M/L)
Govern	No rules or policy is specified.	Written order, cancellation, return and refund policy communicated to customers.	No agreed rules for customers or for me when handling returns, cancellations or refunds	A detailed policy for returns and orders.	M
Govern	The owner handles the business activities without a documented incident process.	Responsibilities and procedures are defined for security incidents	Delays or confusion when an account is compromised	Document who handles incidents, customer communication and recovery.	M
Identify	No inventory list of devices, data and/or accounts	A maintained inventory of accounts, devices and data, with the most valuable assets identified	Without a list, risks such as a hacked account, a fake profile or a fake payment confirmation haven't been thought through	Create inventory for accounts, devices and data.	M
Protect	Business account relies on one password without additional security	Strong, unique passwords in a password manager, with MFA, changed only if compromised	Weak or reused passwords may be easy to hack.	Enable MFA on social media accounts, use a password manager.	H

Function	Current practice	Target practice	Gap	Action	Priority (H/M/L)
Detect	Login alerts and account activity is not checked regularly.	Suspicious logins and unfamiliar accounts activity are reviewed regularly.	Unauthorized access to social media accounts may remain unnoticed	Enable login alerts and review account activity weekly.	M
Respond	No established process of handling payment fraud	Suspicious transactions are promptly investigated and reported.	Financial loss may increase because of delayed action.	Write a one-page checklist: how to verify and report payment fraud, who to tell	H
Recover	Order records do not have a separate backup	Essential order and customer records to be maintained in a separate place so that they can be restored when required.	Lost orders or customer information can lead to missed deliveries and revenue loss.	Back up the order register weekly.	H

3. TIER SELF-ASSESSMENT

Current Tier: 1
Reasoning: Security depends on my own day-to-day habits, there are no written policies, no inventory, and no defined response if an account is compromised.
Target Tier in 12 months: 2

4. TOP PRIORITIZED ACTIONS

1. Enable MFA and use strong passwords. **Why first:** Prevents unauthorized access to business accounts with minimal cost and effort.
2. Maintain secure backups of customer and order records. W**hy:** Prevents permanent data loss if a phone is lost or damaged.
3. Verify digital payments before confirming orders. **Why:** Reduces the risk of payment fraud and financial losses.
4. Create written order, refund, and cancellation policies. **Why:** Reduces customer disputes and establishes clear business rules.
5. Prepare an incident-response plan. **Why:** Helps the owner respond quickly to hacked accounts or suspected fraud.

5. WHAT I WOULD DO NEXT

In six months, I would review the completed actions, test backup restoration, check account security, and reassess any remaining gaps. If Crumbline Cookies expands and begins serving larger business customers, ISO 27001 would be useful for establishing a formal information security management system, while SOC 2 may be relevant if customers require independent assurance about security controls.